



Vulnerability Assessment &
Penetration Testing (VAPT) Report

Unity Health (PTY) Ltd

30th April 2024



TABLE OF CONTENTS

1	EXECUTIVE SUMMARY	3
2	SCOPE OF TESTING.....	3
3	METHODOLOGIES USED	3
3.1	NMAP / ZENMAP.....	3
3.2	NESSUS	3
3.3	GREENBONE ENTERPRISE	4
4	STAY ONE STEP AHEAD OF ATTACKERS.....	4
4.1	OWASP.....	5
4.2	BRUTE FORCE.....	5
5	VIRTUAL SERVERS	6
5.1	PRODUCTION SERVER – 41.76.215.242	6
5.2	TEST SERVER – 41.76.215.103	11
5.3	VP SERVER – 41.76.215.27	14
6	REPORTING CONCLUSION	17
7	AUDITORS	17



1 EXECUTIVE SUMMARY

The purpose of this assessment was to point out security loopholes, business logic errors, and missing best security practices. The tests were carried out assuming the identity of an attacker or a malicious user but, no harm was made to the functionality or working of the application / network. A full scan was also performed on the infrastructure to demonstrate a known attack, i.e. someone on the internal network or same public subnetted infrastructure. The scans and brute force were performed over 10 (ten) business days, as full and slow comprehensive audits were performed. These types of scans also look at unknown connectivity options, including packet SYN requests.

The overall results will be published below, High-level, Sautech is comfortable and happy with the results. Some recommendations however, is offered and also mentioned throughout this document.

2 SCOPE OF TESTING

Security assessments include testing for security loopholes in the scope defined below. Apart from the following, no other information was provided. Nothing was assumed at the start of the security assessment. The following scope of servers were covered under the security audit:

- Server hosted at Afrihost that is behind a managed CheckPoint Firewall
- Four Hosted Virtual Servers namely:
 - Production Server - 41.76.215.242
 - Test Server - 41.76.215.103
 - VP Server - 41.76.215.27
 - ODS Server - 41.76.213.162

3 METHODOLOGIES USED

Sautech performed various audit techniques that includes the following:

3.1 Nmap / Zenmap

Nmap, short for Network Mapper, is a free and open source tool used for vulnerability checking, port scanning and, of course, network mapping. Despite being created back in 1997, Nmap remains the gold standard against which all other similar tools either commercial or open source, are judged.

To deploy Nmap, users originally had to have some advanced programming skills, with the introduction of the Zenmap tool for Nmap, which adds a graphical interface that makes launching the program and analysing the returned output it generates much more accessible.

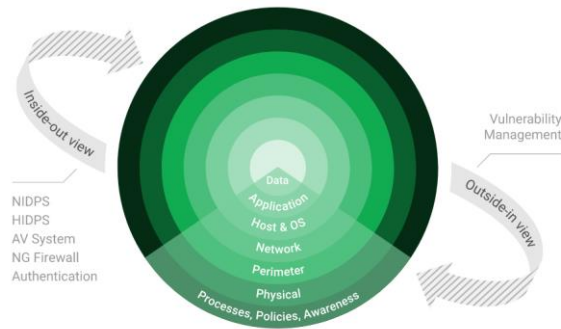
3.2 Nessus

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network. It does this by running over 1200 checks on a given computer, testing to see if any of these attacks could be used to break into the computer or otherwise harm it.



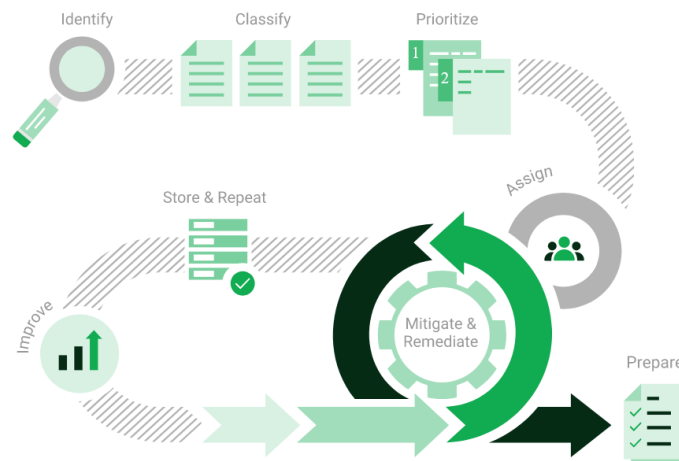
3.3 Greenbone Enterprise

Greenbone is the world's most widely used vulnerability management provider.



4 STAY ONE STEP AHEAD OF ATTACKERS

IT security is a process – Open Source vulnerability management provides the foundation. Once you know where the chinks are in your armor, you can do something about them.

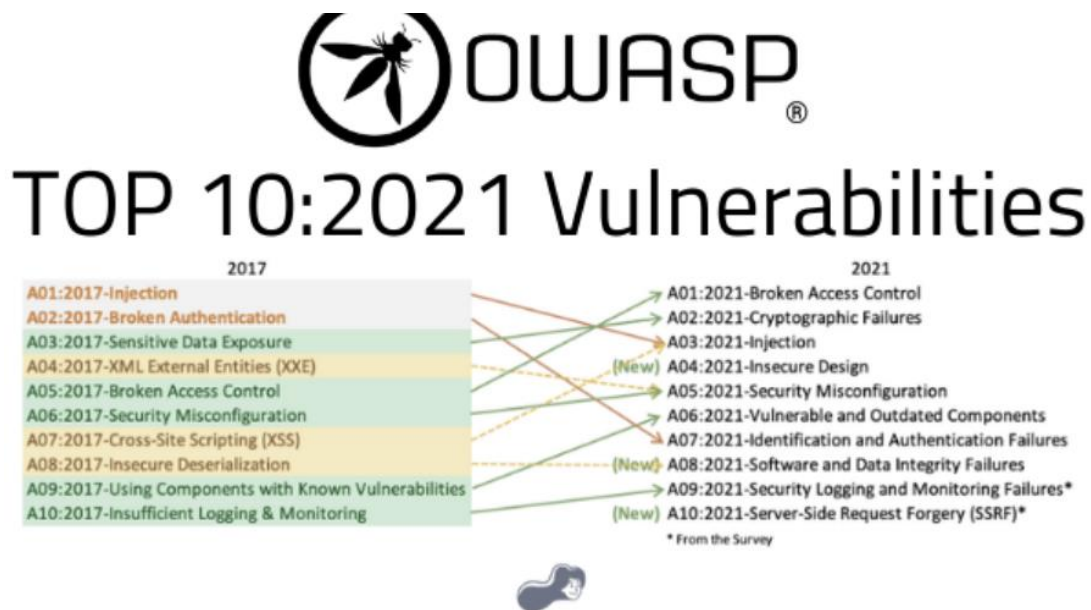


The process – from recognition to remedy and monitoring – represents a continuous cycle. You'll always be one step ahead of attackers.



4.1 OWASP

The **Open Web Application Security Project (OWASP)** is an online community that produces freely-available articles, methodologies, documentation, tools, and technologies in the field of web application security. The Open Web Application Security Project (OWASP) provides free and open resources. It is led by a non-profit called The OWASP Foundation. The OWASP Top 10 - 2021 is the published result of recent research based on comprehensive data compiled from over 40 partner organizations.



4.2 BRUTE FORCE

- A brute force attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys. It is a simple yet reliable tactic for gaining unauthorized access to individual accounts and organizations' systems and networks. The hacker tries multiple usernames and passwords, often using a computer to test a wide range of combinations, until they find the correct login information.
- The name "brute force" comes from attackers using excessively forceful attempts to gain access to user accounts. Despite being an old cyberattack method, brute force attacks are tried and tested and remain a popular tactic with hackers



4.3 Applications used in Brute Force Include:

Hydra is a parallelized network login cracker built in various operating systems like Kali Linux, Parrot and other major penetration testing environments. Hydra works by using different approaches to perform brute-force attacks in order to guess the right username and password combination. Hydra is commonly used by penetration testers together with a set of programmes like crunch,[2] cupp[3] etc, which are used to generate wordlists. Hydra is then used to test the attacks using the wordlists that these programmes created.

Over 2.5 Million + Username and password combos are used to Brute force application like RDP, SSH etc.

5 VIRTUAL SERVERS

5.1 Production Server – 41.76.215.242

We have performed three types of scans / attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments.
- Bruce Force Attacks.

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

Port	Protocol	State	Service	Version
80	tcp	open	http	Apache httpd
443	tcp	open	http	Apache httpd

Remote Operating System Detection:

- Used Port: 80/tcp (open)
- Used Port: 443/tcp (open)

ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:



41.76.215.242



Vulnerabilities

Total: 91

SEVERITY	CVSS V3.0	VPR SCORE	PLUGIN	NAME
CRITICAL	9.8	7.4	95438	Apache Tomcat 6.0.x < 6.0.48 / 7.0.x < 7.0.73 / 8.0.x < 8.0.39 / 8.5.x < 8.5.8 / 9.0.x < 9.0.0.M13 Multiple Vulnerabilities
CRITICAL	9.8	6.7	111067	Apache Tomcat 8.0.0 < 8.0.53 Security Constraint Weakness
CRITICAL	9.1	5.2	121120	Apache Tomcat 7.0.x < 7.0.76 / 8.0.x < 8.0.42 / 8.5.x < 8.5.12 / 9.0.x < 9.0.0.M18 Improper Access Control
CRITICAL	10.0	-	171342	Apache Tomcat SEoL (8.0.x)
HIGH	8.8	6.7	88937	Apache Tomcat 8.0.0.RC1 < 8.0.32 Multiple Vulnerabilities
HIGH	8.1	9.2	103697	Apache Tomcat 8.0.0.RC1 < 8.0.47 Multiple Vulnerabilities
HIGH	7.5	3.6	96003	Apache Tomcat 6.0.16 < 6.0.50 / 7.0.x < 7.0.75 / 8.0.x < 8.0.41 / 8.5.x < 8.5.9 / 9.0.x < 9.0.0.M15 NIO HTTP Connector Information Disclosure
HIGH	7.5	6.0	94578	Apache Tomcat 6.0.x < 6.0.47 / 7.0.x < 7.0.72 / 8.0.x < 8.0.37 / 8.5.x < 8.5.5 / 9.0.x < 9.0.0.M10 Multiple Vulnerabilities
HIGH	7.5	3.6	99367	Apache Tomcat 6.0.x < 6.0.53 / 7.0.x < 7.0.77 / 8.0.x < 8.0.43 Pipelined Requests Information Disclosure
HIGH	7.5	4.4	121119	Apache Tomcat 7.0.x < 7.0.70 / 8.0.x < 8.0.36 / 8.5.x < 8.5.3 / 9.0.x < 9.0.0.M8 Denial of Service
HIGH	7.5	4.4	100681	Apache Tomcat 7.0.x < 7.0.78 / 8.0.x < 8.0.44 / 8.5.x < 8.5.15 / 9.0.x < 9.0.0.M21 Remote Error Page Manipulation
HIGH	7.5	4.4	121119	Apache Tomcat 7.0.x < 7.0.70 / 8.0.x < 8.0.36 / 8.5.x < 8.5.3 / 9.0.x < 9.0.0.M8 Denial of Service
HIGH	7.5	4.4	100681	Apache Tomcat 7.0.x < 7.0.78 / 8.0.x < 8.0.44 / 8.5.x < 8.5.15 / 9.0.x < 9.0.0.M21 Remote Error Page Manipulation
HIGH	7.5	3.6	121124	Apache Tomcat 8.0.x < 8.0.52 / 8.5.x < 8.5.31 / 9.0.x < 9.0.8 Denial of Service
HIGH	7.5	3.6	166906	Apache Tomcat 9.0.0-M1 < 9.0.68 Request Smuggling Vulnerability
HIGH	7.5	3.6	171657	Apache Tomcat 9.0.0.M1 < 9.0.71



HIGH	7.5	3.6	186365	Apache Tomcat 9.0.0.M1 < 9.0.83
HIGH	7.5	4.4	192042	Apache Tomcat 9.0.0.M1 < 9.0.86 multiple vulnerabilities
HIGH	7.5	4.4	160894	Apache Tomcat 9.0.13 < 9.0.63 vulnerability
HIGH	7.5	3.6	169459	Apache Tomcat 9.0.40 < 9.0.69
HIGH	7.5	6.1	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
HIGH	7.3	3.4	83765	Apache Tomcat 8.0.x < 8.0.17 Security Manager Bypass
MEDIUM	6.5	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.1	3.0	180194	Apache Tomcat 9.0.0.M1 < 9.0.80
MEDIUM	6.1	3.0	162498	Apache Tomcat 9.0.30 < 9.0.65 vulnerability
MEDIUM	5.9	6.7	187315	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)
MEDIUM	5.3	6.7	182809	Apache Tomcat 9.0.0.M1 < 9.0.81 multiple vulnerabilities
MEDIUM	5.3	2.2	121123	Apache Tomcat < 8.0.30 Directory Disclosure
MEDIUM	5.3	-	12085	Apache Tomcat Default Files
MEDIUM	4.3	2.2	121117	Apache Tomcat 7.0.x < 7.0.65 / 8.0.x < 8.0.27 Directory Traversal
MEDIUM	4.3	1.4	102588	Apache Tomcat 8.0.0.RC1 < 8.0.45 Cache Poisoning
MEDIUM	4.3	1.4	173251	Apache Tomcat 9.0.0.M1 < 9.0.72
MEDIUM	5.0*	-	12218	mDNS Detection (Remote Network)
LOW	3.7	4.4	106976	Apache Tomcat 8.0.0.RC1 < 8.0.50 Security Constraint Weakness
LOW	3.7	1.4	159462	Apache Tomcat 8.x < 8.5.78 Spring4Shell (CVE-2022-22965) Mitigations
LOW	3.7	3.6	70658	SSH Server CBC Mode Ciphers Enabled
LOW	3.7	-	153953	SSH Weak Key Exchange Algorithms Enabled
LOW	3.1	2.2	10759	Web Server HTTP Header Internal IP Disclosure
INFO	N/A	-	10114	ICMP Timestamp Request Remote Date Disclosure
INFO	N/A	-	10223	RPC portmapper Service Detection
INFO	N/A	-	48204	Apache HTTP Server Version



INFO	N/A	-	159843	Apache Shiro HTTP Detection
INFO	N/A	-	39446	Apache Tomcat Detection
INFO	N/A	-	39520	Backported Security Patch Detection (SSH)
INFO	N/A	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	54615	Device Type
INFO	N/A	-	84502	HSTS Missing From HTTPS Server
INFO	N/A	-	43111	HTTP Methods Allowed (per directory)
INFO	N/A	-	10107	HTTP Server Type and Version
INFO	N/A	-	12053	Host Fully Qualified Domain Name (FQDN) Resolution
INFO	N/A	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	46215	Inconsistent Hostname and IP Address
INFO	N/A	-	11011	Microsoft Windows SMB Service Detection
INFO	N/A	-	106716	Microsoft Windows SMB2 and SMB3 Dialects Supported (remote check)
INFO	N/A	-	11219	Nessus SYN scanner
INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	42823	Non-compliant Strict Transport Security (STS)
INFO	N/A	-	11936	OS Identification
INFO	N/A	-	117886	OS Security Patch Assessment Not Available
INFO	N/A	-	181418	OpenSSH Detection
INFO	N/A	-	66334	Patch Report
INFO	N/A	-	26024	PostgreSQL Server Detection
INFO	N/A	-	53335	RPC portmapper (TCP)
INFO	N/A	-	70657	SSH Algorithms and Languages Supported
INFO	N/A	-	149334	SSH Password Authentication Accepted
INFO	N/A	-	10881	SSH Protocol Versions Supported



INFO	N/A	-	153588	SSH SHA-1 HMAC Algorithms Enabled
INFO	N/A	-	10267	SSH Server Type and Version Information
INFO	N/A	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	45410	SSL Certificate 'commonName' Mismatch
INFO	N/A	-	10863	SSL Certificate Information
INFO	N/A	-	95631	SSL Certificate Signed Using Weak Hashing Algorithm (Known CA)
INFO	N/A	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	94761	SSL Root Certification Authority Certificate Information
INFO	N/A	-	51891	SSL Session Resume Supported
INFO	N/A	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	22964	Service Detection
INFO	N/A	-	42822	Strict Transport Security (STS) Detection
INFO	N/A	-	84821	TLS ALPN Supported Protocol Enumeration
INFO	N/A	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	138330	TLS Version 1.3 Protocol Detection
INFO	N/A	-	110723	Target Credential Status by Authentication Protocol - No Credentials Provided
INFO	N/A	-	10287	Traceroute Information
INFO	N/A	-	19288	VNC Server Security Type Detection
INFO	N/A	-	65792	VNC Server Unencrypted Communication Detection
INFO	N/A	-	10342	VNC Software Detection
INFO	N/A	-	135860	WMI Not Available
INFO	N/A	-	100669	Web Application Cookies Are Expired
INFO	N/A	-	20108	Web Server / Application favicon.ico Vendor Fingerprinting
INFO	N/A	-	10386	Web Server No 404 Error Code Check
INFO	N/A	-	11422	Web Server Unconfigured - Default Install Page Present



iii) Brute Force

Randomised usernames with a word list containing more than 2.5 words and common passwords were brute forced SSH's onto the server using Hydra.

Hydra works by **using different approaches to perform brute-force attacks in order to guess the right username and password combination**. Hydra is commonly used by penetration testers together with a set of programmes like crunch, cupp etc, which are used to generate wordlists.

```
(root@kali) ~ [usr/share/wordlists/dirb]
# hydra -l mip -P /usr/share/wordlists/dirb/big.txt 41.76.215.242 -t 4 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-04-25 11:30:16
[DATA] max 4 tasks per 1 server, overall 4 tasks, 20469 login tries (l:1/p:20469), ~5118 tries per task
[DATA] attacking ssh://41.76.215.242:22/
[STATUS] 40.00 tries/min, 40 tries in 00:01h, 20429 to do in 08:31h, 4 active
[STATUS] 28.00 tries/min, 84 tries in 00:03h, 20385 to do in 12:09h, 4 active
[STATUS] 26.29 tries/min, 184 tries in 00:07h, 20285 to do in 12:52h, 4 active
[STATUS] 25.87 tries/min, 388 tries in 00:15h, 20081 to do in 12:57h, 4 active
```

As per the HYDRA screen shot above, all know accounts have been scanned and with no passwords found. We are satisfied with the results.

5.2 Test Server – 41.76.215.103

We have performed two types of scans/attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter but also include local network.
- Vulnerability assessments

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

Port	Protocol	State	Service	Version
80	tcp	open	http	
443	tcp	open	https	

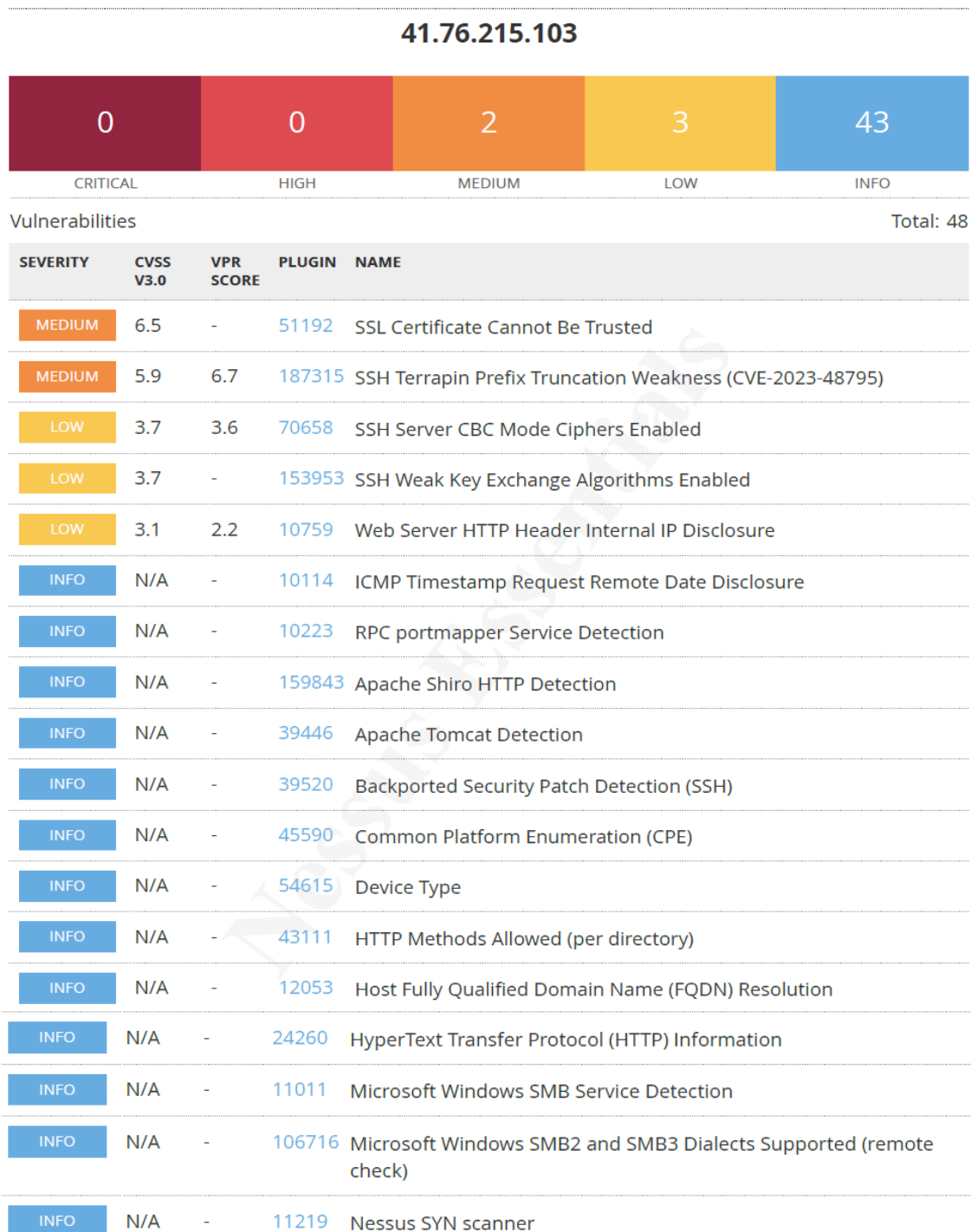
Remote Operating System Detection:

- Used Port: 80/tsp (open)
- Used Port: 443/tsp (open)



ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:





INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	42823	Non-compliant Strict Transport Security (STS)
INFO	N/A	-	11936	OS Identification
INFO	N/A	-	117886	OS Security Patch Assessment Not Available
INFO	N/A	-	181418	OpenSSH Detection
INFO	N/A	-	66334	Patch Report
INFO	N/A	-	53335	RPC portmapper (TCP)
INFO	N/A	-	70657	SSH Algorithms and Languages Supported
INFO	N/A	-	149334	SSH Password Authentication Accepted
INFO	N/A	-	10881	SSH Protocol Versions Supported
INFO	N/A	-	153588	SSH SHA-1 HMAC Algorithms Enabled
INFO	N/A	-	10267	SSH Server Type and Version Information
INFO	N/A	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	45410	SSL Certificate 'commonName' Mismatch
INFO	N/A	-	10863	SSL Certificate Information
INFO	N/A	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	22964	Service Detection
INFO	N/A	-	42822	Strict Transport Security (STS) Detection
INFO	N/A	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	84821	TLS ALPN Supported Protocol Enumeration
INFO	N/A	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	138330	TLS Version 1.3 Protocol Detection
INFO	N/A	-	110723	Target Credential Status by Authentication Protocol - No Credentials Provided
INFO	N/A	-	10287	Traceroute Information
INFO	N/A	-	135860	WMI Not Available
INFO	N/A	-	20108	Web Server / Application favicon.ico Vendor Fingerprinting
INFO	N/A	-	10386	Web Server No 404 Error Code Check



5.3 VP Server – 41.76.215.27

We have performed two types of scans / attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments.

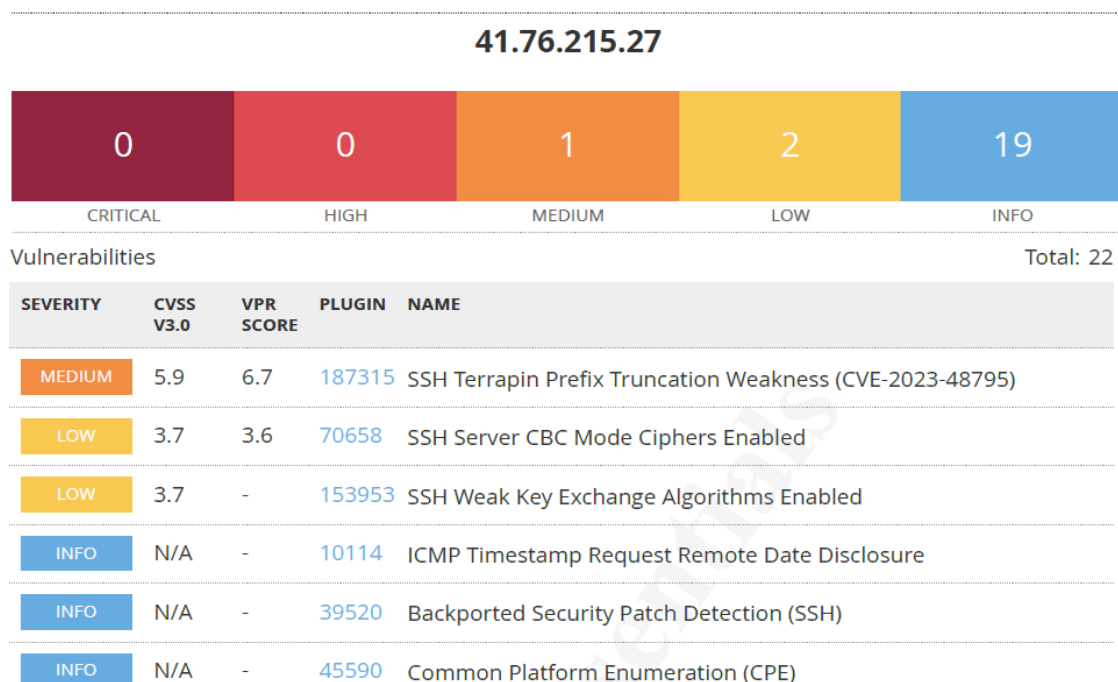
i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

No Port Mapping Exposures were found. This is due to Checkpoint Firewall Policies not exposing any Port. We are very pleased with this result.

ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:





INFO	N/A	-	12053	Host Fully Qualified Domain Name (FQDN) Resolution
INFO	N/A	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	11219	Nessus SYN scanner
INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	50350	OS Identification Failed
INFO	N/A	-	181418	OpenSSH Detection
INFO	N/A	-	66334	Patch Report
INFO	N/A	-	70657	SSH Algorithms and Languages Supported
INFO	N/A	-	149334	SSH Password Authentication Accepted
INFO	N/A	-	10881	SSH Protocol Versions Supported
INFO	N/A	-	153588	SSH SHA-1 HMAC Algorithms Enabled
INFO	N/A	-	10267	SSH Server Type and Version Information
INFO	N/A	-	22964	Service Detection
INFO	N/A	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	10287	Traceroute Information
INFO	N/A	-	11154	Unknown Service Detection: Banner Retrieval

5.4 ODS Server – 41.76.213.162

We have performed two types of scans / attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments.

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

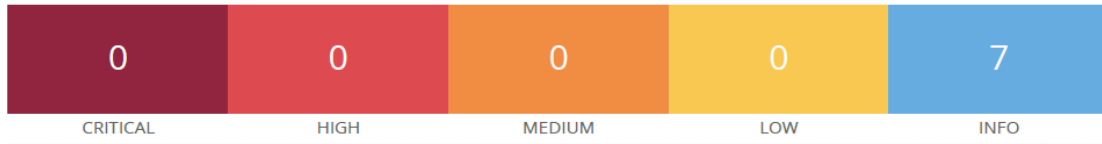
No Port Mapping Exposures were found. This is due to Checkpoint Firewall Policies not exposing any Port. We are very pleased with this result.



ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

41.76.213.162



Vulnerabilities

Total: 7

SEVERITY	CVSS V3.0	VPR SCORE	PLUGIN	NAME
INFO	N/A	-	12053	Host Fully Qualified Domain Name (FQDN) Resolution
INFO	N/A	-	46215	Inconsistent Hostname and IP Address
INFO	N/A	-	11219	Nessus SYN scanner
INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	50350	OS Identification Failed
INFO	N/A	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	10287	Traceroute Information



6 REPORTING CONCLUSION

Based on the OWASP reports it is best to attach these separate to the reporting document. These reports can then be shared with the relevant contractors and/or support personnel to implement the changes and updates.

It is our view that from External Testing where the SSH port are not open to public, these vulnerabilities then become academic. However, we still recommend that the changes be implemented. As Unity Health is behind the managed checkpoint Firewall, not even the local subnetted public network can exploit the SSH vulnerabilities.

The HTTPS updates as these are open to the public, low and medium risk, should be tested and implemented as soon as possible.

From a Hosted Infrastructure point of view, we are happy with the results. We do recommend that SenitnelOne is implemented into the production environment as soon as possible.

Ten addendum reports are attached to this report and should be read as one document.

With the following test performed:

- Network scanning
- IDS/IPS disabled
- Knows network attack (from Internet to the FW)
- External HTTP and Port exploits
- Vulnerability assessment on CVE
- Penetration testing on login ports i.e.: ssh open

7 AUDITORS

These audits were concluded over a period of 10 (ten) business days.
We hereby confirm that the above information is true and correct:

30th April 2024 – Krugersdorp, South Africa

Riaan van Jaarsveld
Security Expert – CCSA / Certified Pen Tester

Lukas Janse van Rensburg
Security Engineer